

Cloud Security Checklist

Seven areas to check, plus a 30-day quick-win plan

DuRuVaSa CloudSec Cybersecurity consulting: threat detection, compliance, 24/7 monitoring

Use this checklist to get a quick, honest picture of your cloud security. Tick what is fully in place today. Anything unticked is a conversation worth having. Aim to close the gaps in the first sections first: identity and monitoring prevent and reveal most real-world incidents.

1. Identity and access

- ☐ Multi-factor authentication is required for every user and every admin account
- ☐ Shared and generic accounts are removed; each person has their own login
- ☐ Access follows least privilege and is reviewed at least quarterly
- ☐ Leavers are deprovisioned the same day; unused accounts are disabled
- ☐ Admin roles are separate from daily-use accounts and are used only when needed
- ☐ Service accounts and API keys are inventoried, scoped and rotated

2. Data protection

- ☐ You know where sensitive data lives and who can reach it (a simple data map)
- ☐ Data is encrypted at rest and in transit
- ☐ Storage buckets, databases and snapshots are not publicly exposed
- ☐ Encryption keys and secrets live in a managed vault, not in code or chat
- ☐ Retention rules exist so old data is deleted when no longer needed

3. Logging and monitoring

- ☐ Audit logging is on for logins, configuration changes and data access
- ☐ Logs are sent to a separate location that attackers cannot easily erase
- ☐ Alerts exist for impossible-travel logins, privilege changes and mass downloads
- ☐ Someone owns alert triage and knows what to do at 2 a.m.
- ☐ Monitoring covers cloud, endpoints and network, not just one of them

4. Configuration and network

- ☐ A baseline for secure configuration exists and drift is detected
- ☐ Public endpoints are inventoried; unused ports and services are closed
- ☐ Systems and dependencies are patched on a defined schedule
- ☐ Network segmentation limits how far an intruder can move
- ☐ Infrastructure is defined as code and changes are reviewed

5. Backup and resilience

- ☐ Backups are encrypted and kept separate from production credentials
- ☐ Restores are tested on a schedule, not just backups taken
- ☐ Recovery time and recovery point targets are written down
- ☐ A copy of critical backups cannot be altered or deleted by a compromised admin

6. Incident response

- ☐ A short incident plan names who decides, who acts and who communicates
- ☐ Contact details for key people, vendors and advisors are available offline
- ☐ The plan is rehearsed at least once a year with a realistic scenario
- ☐ Lessons from every incident or near miss feed back into controls

7. Compliance and governance

- ☐ You know which standards, regulations and customer requirements apply
- ☐ Each control has an owner and a source of evidence
- ☐ Evidence is collected continuously so audits are routine, not a scramble
- ☐ Policies are short, current and easy to find; staff receive security awareness training
- ☐ Third-party and supplier risks are reviewed before and during the relationship

Your 30-day quick-win plan

- | | |
|----------------------|---|
| Days 1 to 7 | Turn on MFA everywhere. Remove shared accounts. List public endpoints and storage. |
| Days 8 to 14 | Switch on audit logging and route it to a protected location. Define who triages alerts. |
| Days 15 to 21 | Review access and offboard stale accounts. Test one backup restore. |
| Days 22 to 30 | Write the one-page incident plan and run a 30-minute tabletop. Start an evidence tracker. |

Want help closing the gaps?

Book a consultation or take the 2-minute security self-check on our website.

www.duruvasa.com | info@duruvasa.com

This checklist is general guidance and not a substitute for a professional security assessment.